Data Retention and Destruction Policy

Organization: COOKIE-BANNER.CA **Contact:** security@cookie-banner.ca **Effective Date:** March 28, 2026 **Last Reviewed:** March 28, 2026 **Next Review:** March 28, 2027

---

1. Purpose and Scope

This policy defines how COOKIE-BANNER.CA retains, archives, and destroys data across its cookie consent management platform. It applies to all data processed by the organization and its infrastructure providers (Vercel, Supabase, Stripe). COOKIE-BANNER.CA operates as a fully virtual organization with no physical offices or on-premises data storage.

This policy supports compliance with GDPR, PIPEDA, Quebec Law 25, and PECR.

---

2. Data Classification

Category	Examples	Classification
Consent Records	Visitor consent preferences, timestamps, consent string, domain	Business-Critical
Customer Account Data	Email address, organization name, team members	Confidential
Payment Data	Subscription status, plan tier (card details held by Stripe)	Restricted
Application Configuration	Banner settings, color schemes, integrations	Standard
Application Logs	Server logs, error traces, request metadata	Internal
Backups	Database snapshots (managed by Supabase)	Confidential

---

3. Retention Periods

Data Type	Retention Period	Justification
Consent records	**3 years** from collection	Regulatory proof-of-consent requirement (GDPR Art. 7, Law 25 s.8)
Customer account data	**Duration of account + 90 days**	Service delivery; 90-day grace period for reactivation
Payment and billing records	**7 years** from transaction date	Tax and financial record-keeping obligations
Application configuration	**Duration of account + 30 days**	Allows brief recovery window post-cancellation
Application logs (Vercel)	**30 days**	Operational troubleshooting; Vercel auto-purges
Database backups (Supabase)	**30 days** rolling	Disaster recovery; managed by Supabase retention policy
Authentication session data	**30 days** from last activity	Session management (NextAuth.js)

---

4. Data Destruction Procedures

4.1 Automated Destruction

- **Consent records** older than 3 years are purged by a scheduled database job that runs monthly.
- **Expired sessions** are cleared automatically by NextAuth.js on a rolling basis.
- **Application logs** expire automatically per Vercel's 30-day log retention.

4.2 Account Deletion

When a customer deletes their account or requests deletion:

1. Account data, banner configurations, and team member records are deleted from the production database within **30 days**.
2. Consent records collected on behalf of the customer are deleted within **30 days**, unless a legal retention obligation applies.
3. Stripe customer and subscription objects are cancelled; Stripe retains transaction records per its own data retention obligations.
4. A confirmation email is sent to the customer upon completion.

4.3 Destruction Methods

- **Database records:** Hard deletion via SQL `DELETE` statements against Supabase PostgreSQL. No soft-delete retention beyond the stated periods.
- **Backups:** Supabase manages automated backup rotation on a 30-day rolling cycle. Deleted records naturally age out of the backup window.
- **Logs:** Vercel logs auto-expire. No manual destruction is required.

---

5. Cloud Data Lifecycle

COOKIE-BANNER.CA does not operate its own servers or data centers. All data resides with SOC 2 Type II certified providers:

Provider	Data Held	Retention Control	Certification
Supabase	Database, backups, file storage	Direct SQL control; 30-day backup rotation	SOC 2 Type II
Vercel	Application hosting, server logs	30-day log auto-expiry	SOC 2 Type II
Stripe	Payment methods, transaction history	Managed by Stripe per PCI DSS requirements	PCI DSS Level 1

Upon termination of any provider relationship, COOKIE-BANNER.CA will export or migrate data before the provider's deletion timeline and confirm destruction of residual data in writing.

---

6. Customer Data Deletion Requests

Customers and end users may request data deletion by contacting security@cookie-banner.ca. Requests are processed as follows:

- **Acknowledgment** within 3 business days.
- **Completion** within 30 calendar days.
- **Verification** of requester identity before processing.
- Applies to all data categories unless a legal retention obligation overrides the request (see Section 8).

For GDPR data subjects, the right to erasure (Art. 17) is honored unless an exemption applies. For PIPEDA/Law 25 data subjects, withdrawal of consent and deletion requests are handled equivalently.

---

7. Third-Party Data Handling

COOKIE-BANNER.CA requires that all sub-processors handle data destruction in accordance with their contractual obligations:

- **Supabase:** Data deleted from production is removed from backups within 30 days via rolling retention.
- **Stripe:** Retains transaction data as required by PCI DSS and applicable tax law. COOKIE-BANNER.CA cannot force deletion of Stripe-held payment records but will cancel all associated customer objects.
- **Vercel:** Logs are purged automatically. No persistent customer personal data is stored at the Vercel layer.

---

8. Exceptions and Legal Holds

Data may be retained beyond the standard periods when:

- Required by a **legal hold** (e.g., litigation, regulatory investigation, audit).
- Needed to comply with **tax or financial reporting** obligations.
- Subject to an **active dispute** or chargeback with a payment provider.
- Required to demonstrate **proof of consent** under GDPR, PIPEDA, Law 25, or PECR.

Legal holds are authorized by the founder and documented with the scope, reason, and expected duration. Held data is destroyed within 30 days of the hold being lifted.

---

9. Review Schedule

This policy is reviewed **annually** or sooner if triggered by:

- A change in applicable privacy legislation.
- A material change in infrastructure providers.
- A data breach or security incident.
- Significant changes to the types of data processed.

COOKIE-BANNER.CA – security@cookie-banner.ca